

SOFTWARE SUPPLY CHAIN ATTACKS IN CI/CD PIPELINES

Software Seguro

Daniel Pereira

Eduardo Marques

João Cardoso

MOTIVAÇÃO & PROBLEMA

A adoção de CI/CD pipelines acelera a entrega de software, mas introduz uma superfície de ataque mais ampla e complexa

Software moderno depende de centenas de third-party packages (npm, PyPI, Maven)

Comprometer um único componente upstream pode propagar-se para milhares de consumidores downstream simultaneamente

Defesas atuais são inconsistentes; tensão permanente entre velocidade de entrega e segurança

FUNDAMENTAÇÃO

Software Supply Chain

Todos os componentes, processos e atores envolvidos na produção e entrega de software

Ao incluir um pacote, confia-se também em todas as suas dependências, sendo estas raramente verificadas

CI/CD Pipeline

Têm acesso privilegiado: credenciais, tokens, registries, ambientes de produção

Modelo de ameaça

Attacker externo, insider comprometido, ou contribuidor malicioso que ganha confiança gradualmente

TAXONOMIA DE VETORES DE ATAQUE

Dependency
Poisoning

Malicious
Packages

Pipeline
Compromise

DEPENDENCY POISONING

Refere-se a ataques em que o código malicioso é introduzido num pacote de software legítimo do qual uma aplicação depende. Em vez de realizar um ataque direto, o atacante compromete um componente que o alvo do ataque considera ser de confiança.

Principais Técnicas:

Dependency Confusion

Pacote público malicioso com versão superior ao pacote fidedigno

Typosquatting

Nomes visualmente semelhantes a bibliotecas populares

Dependency Hijacking

Um atacante assume a conta de um maintainer para publicar uma versão maliciosa de um pacote usado por utilizadores

MALICIOUS PACKAGES

Pacotes maliciosos são criados desde o início com intenções prejudiciais e publicados em repositórios públicos sob identidades ilusórias. Qualquer pessoa pode criar e publicar um pacote no npm, PyPI, com verificação mínima.

Principais Técnicas:

Typosquatting

Nomes visualmente semelhantes a bibliotecas populares

Starjacking

Pacotes falsos fazem uma referência a repositórios GitHub legítimos para ganhar credibilidade

Data Exfiltration

Payload crítico de pacotes maliciosos que, após a instalação, recolhe dados sensíveis e envia-os para o atacante

PIPELINE COMPROMISE

CI/CD pipelines ocupam uma posição crítica no processo de entrega de software, uma vez que lidam regularmente com credenciais sensíveis e possuem acesso direto a ambientes de produção e registos de artefactos.

Principais Técnicas:

Direct PPE

Ocorre quando um atacante altera diretamente o ficheiro de configuração do CI, através de pushes ou pull requests

Indirect PPE

Ocorre quando o atacante injeta código malicioso em ficheiros usados pelo pipeline, sem alterar a sua configuração

Public PPE

Ocorre em repositórios públicos quando pipelines executam código de contribuintes externos sem revisão

Secret Exposure and Build System Compromise

Ocorre quando um atacante executa código no pipeline e consegue facilmente aceder e exfiltrar segredos expostos

CASE STUDY

SOLARWINDS

A SolarWinds é uma empresa americana que desenvolve ferramentas de monitorização e gestão de infraestrutura IT. Um dos seus produtos mais relevantes é o **Orion Platform**, usado por governos e infraestruturas críticas.

Os atacantes infiltraram-se no ambiente interno da SolarWinds em 2019 e ficaram em modo de reconhecimento durante meses

Criaram uma ferramenta chamada **SUNSPOT** que monitorizava o processo de **build** e, quando detetava que o Orion estava a ser compilado, substituíva automaticamente um ficheiro de código pelo código malicioso → **Backdoor SUNBURST**

A injeção acontecia **depois** de o código fonte ser carregado mas **antes** de o artefacto ser assinado digitalmente → o resultado final era um executável com assinatura válida e legítima

CASE STUDY

SOLARWINDS

A SolarWinds é uma empresa americana que desenvolve ferramentas de monitorização e gestão de infraestrutura IT. Um dos seus produtos mais relevantes é o **Orion Platform**, usado por governos e infraestruturas críticas.

Houve 18.000 downloads do software comprometido e cerca de 100 organizações foram realmente afetadas, incluindo entidades governamentais dos EUA como o Department of Homeland Security e o Treasury, bem como empresas tecnológicas como a Microsoft e a FireEye.

ESTRATÉGIAS DE MITIGAÇÃO DEFESAS ATUAIS

Estratégia	Ameaças Abordadas	Limitações	Custo
SLSA	Protege contra compromissos no build e adulteração de artefactos	Overhead elevado nos níveis 3–4	Alto
SBOM	Visibilidade de dependências, resposta a CVEs	Não previne ataques, apenas lista componentes	Baixo–Médio
<i>Code Signing / Sigstore</i>	Integridade e autenticidade do software	Não garante que o código é seguro	Médio
<i>Dependency Pinning & Auditing</i>	Reduz risco de dependency confusion e updates maliciosos	Ineficaz contra pacotes maliciosos novos	Baixo-Médio
Least Privilege em CI/CD Pipelines	Reduz acesso a credenciais e comprometimento de secrets	Não impede execução de código malicioso	Médio

ANÁLISE CRÍTICA

Porque é que as defesas atuais não chegam:

As técnicas (SLSA, SBOM, code signing) são necessárias mas insuficientes.

Falham quando o atacante:

1. Está dentro do pipeline de build
2. Atua como um maintainer legítimo
3. Compromete dependências upstream

Fragilidade Estrutural do Open Source

- Dependência de poucos maintainers
 - Falta de recursos e financiamento
- O fator humano e organizacional torna-se um vetor de ataque

Trade-off Velocidade vs Segurança

- CI/CD otimizado para rapidez
 - Medidas de segurança impõem custos operacionais adicionais
- Na prática, a segurança é, frequentemente, parcialmente implementada – cria um risco estrutural explorável

OPEN CHALLENGES

Desafios Técnicos

- Verificar a intenção do processo de build (não apenas a integridade)
- Melhorar a detecção de ataques sofisticados e altamente direcionados
- Reduzir o tempo de detecção

Desafios do Ecossistema

- Ferramentas fragmentadas
- Adoção inconsistente de boas práticas
- Falta de verificação do lado do consumidor

Direções Futuras

- Modelos formais para pipelines seguros
- Sistemas escaláveis de confiança/reputação
- Melhor partilha de threat intelligence
- Sustentabilidade da segurança no open-source

FIM

Obrigado pela atenção!

Daniel Pereira

Eduardo Marques

João Cardoso